Cyber Security

LJ University

- Deep Solanki



Information Gathering Methodology



Information Gathering Methodology

- Information gathering, also known as reconnaissance, is a critical first step in cyber security. This process involves collecting data about a target system or network to identify potential vulnerabilities and threats.

- Information gathering is a foundational step in both offensive and defensive cyber security strategies. It helps attackers discover vulnerabilities but also aids defenders in fortifying systems. Regardless of the intent, it requires a deep understanding of available tools, techniques, and ethical considerations. In the world of cyber security, proper information gathering can mean the difference between a successful security breach and a robust defense.

- In cyber security, **active** and **passive** information gathering are two approaches used to collect data about a target system, network, or individual. Both methods have distinct characteristics and are used for different purposes. Below is a detailed comparison of these two types of information gathering.

Information Gathering Methodology

1. **Passive Information Gathering :**

- Passive information gathering involves collecting data from publicly available sources without directly interacting with the target system. The goal is to remain undetected while gathering as much information as possible.

- **Characteristics :**

a) **Non-Intrusive** : It does not interact directly with the target system or network. This means there is minimal risk of detection by the target.
b) **Publicly Available Data** : It relies on information that is accessible in the public domain, such as domain records, website content, social media, etc.
c) **Low Risk** : Since there is no direct contact with the target, it is less likely to trigger alarms or defensive measures.

Information Gathering Methodology

- **Techniques :**

a. **WHOIS Lookup** : Provides information about the domain name, its owner, registration details, and contact information.
b. **DNS Queries** : Gathering information about the target's domain names, IP addresses, and name-servers.
c. **Search Engines** : Using Google, Bing, or other search engines to uncover exposed information about a target (e.g., documents, sensitive data).
d. **Social Media Mining** : Collecting publicly available information about the target or its employees on platforms like LinkedIn, Facebook, or Twitter.
e. **Web Scraping** : Extracting data from public-facing websites or online databases.
f. **Public Databases** : Accessing government, legal, and other public databases that may have relevant information.

Information Gathering Methodology

- **Tools :**

a. **Maltego** : An OSINT (Open-Source Intelligence) tool for collecting and analyzing data from social media, domain records, and more.
b. **Shodan** : A search engine for internet-connected devices, helping gather information about exposed devices and their vulnerabilities.
c. **Whois Lookup** : Tools like " whois.domaintools.com " to query domain registration details.

- **Example :**

 An attacker researching a company might use Google Dorking to search for exposed sensitive documents or data on the web without ever directly engaging with the company's website or network.

Information Gathering Methodology

2. **Active Information Gathering :**

- Active information gathering involves directly interacting with the target system or network to extract more detailed or specific information. This approach is more intrusive and has a higher risk of detection.

- **Characteristics :**

a) **Intrusive** : It involves actively probing the target system, such as scanning for open ports, banners, or vulnerabilities.
b) **Higher Risk** : Because the target can detect such activities (e.g., through network monitoring or intrusion detection systems), there is a higher risk of being caught or blocked.
c) **Deeper Information** : Active techniques usually provide more detailed, specific, and actionable data compared to passive methods.

Information Gathering Methodology

Techniques :

a. **Port Scanning** : Identifying open ports on a target system, which may provide insight into the services running on the system (e.g., using tools like Nmap).
b. **Banner Grabbing** : Extracting metadata from services or applications running on a server (e.g., HTTP server banners, SSH version numbers) to learn about the software in use.
c. **Vulnerability Scanning** : Using tools to scan a system for known vulnerabilities (e.g., using Nessus or OpenVAS).
d. **Ping Sweeps** : Sending ICMP echo requests to identify live hosts on a network.
e. **Network Sniffing** : Intercepting network traffic to capture sensitive data or patterns (e.g., using Wireshark).
f. **Social Engineering** : Interacting with people to obtain sensitive information, often using techniques like phishing or pretexting.

Information Gathering Methodology

- **Tools :**

a. **Nmap** : A popular tool for network discovery and security auditing, used for scanning open ports, identifying services, and detecting vulnerabilities.
b. **Netcat** : A tool used for banner grabbing and basic network communication.
c. **Burp Suite**: A comprehensive tool used for web application security testing and vulnerability scanning.
d. **Metasploit** : A penetration testing framework used to exploit vulnerabilities on a target system after gathering information.

- **Example :**

 An attacker may use Nmap to scan a target IP address for open ports and services. If they find an open HTTP port, they might proceed to grab the service banner to learn about the web server version.

Information Gathering Methodology

- **Comparison :** Passive vs. Active Information Gathering(most imp)

Aspect	Passive Information Gathering	Active Information Gathering
Risk of Detection	Low (target is unaware of the actions)	High (target can detect probes and scans)
Interactivity	No direct interaction with the target system	Direct interaction with the target system (e.g., scanning, probing)
Data Sources	Publicly available information (websites, WHOIS, social media)	Direct scanning and probing of systems and networks
Tools	OSINT tools (Maltego, WHOIS), search engines, public records	Scanning tools (Nmap, Metasploit), vulnerability scanners
Speed of Information	Slower, as it relies on public data that may not be fully accurate	Faster, as it pulls detailed, direct data from the target system
Legality	Generally legal, as it uses public information	Can be illegal without permission, as it involves direct engagement with a system

Information Gathering Methodology

- **Use Cases :**

1. **Passive Information Gathering** :
   - Used in the early stages of an attack to gather information without being detected.
   - Employed by defenders to analyze their own networks and identify exposed information.
   - Used for reconnaissance in social engineering, where attackers gather background information about individuals or organizations before crafting phishing or pretexting attacks.

2. **Active Information Gathering** :
   - Used in penetration testing to identify vulnerabilities and assess the security of a system.
   - Employed by attackers to discover weaknesses in systems or networks that can be exploited.
   - Used in security audits and vulnerability assessments to proactively identify and patch potential flaws in a system.